Overview Solutions

Not Running

For the best experience, choose the region closest to you. Then, start the lab to begin.

MARK UNFINISHED

Select the region closest to you

US-East

Keyboard layout: US English (US)

Start lab

Tasks

Task 1: Detect malicious responses and rogue authentication servers inside the network

Responder and Inveigh utilize rogue authentication servers to capture user credentials, after LLMNR, NBT-NS and MDNS poisoning is performed.

By deliberately requesting for a non-existing network resource and using honey credentials, you can detect the presence of Responder or Inveigh inside a network.

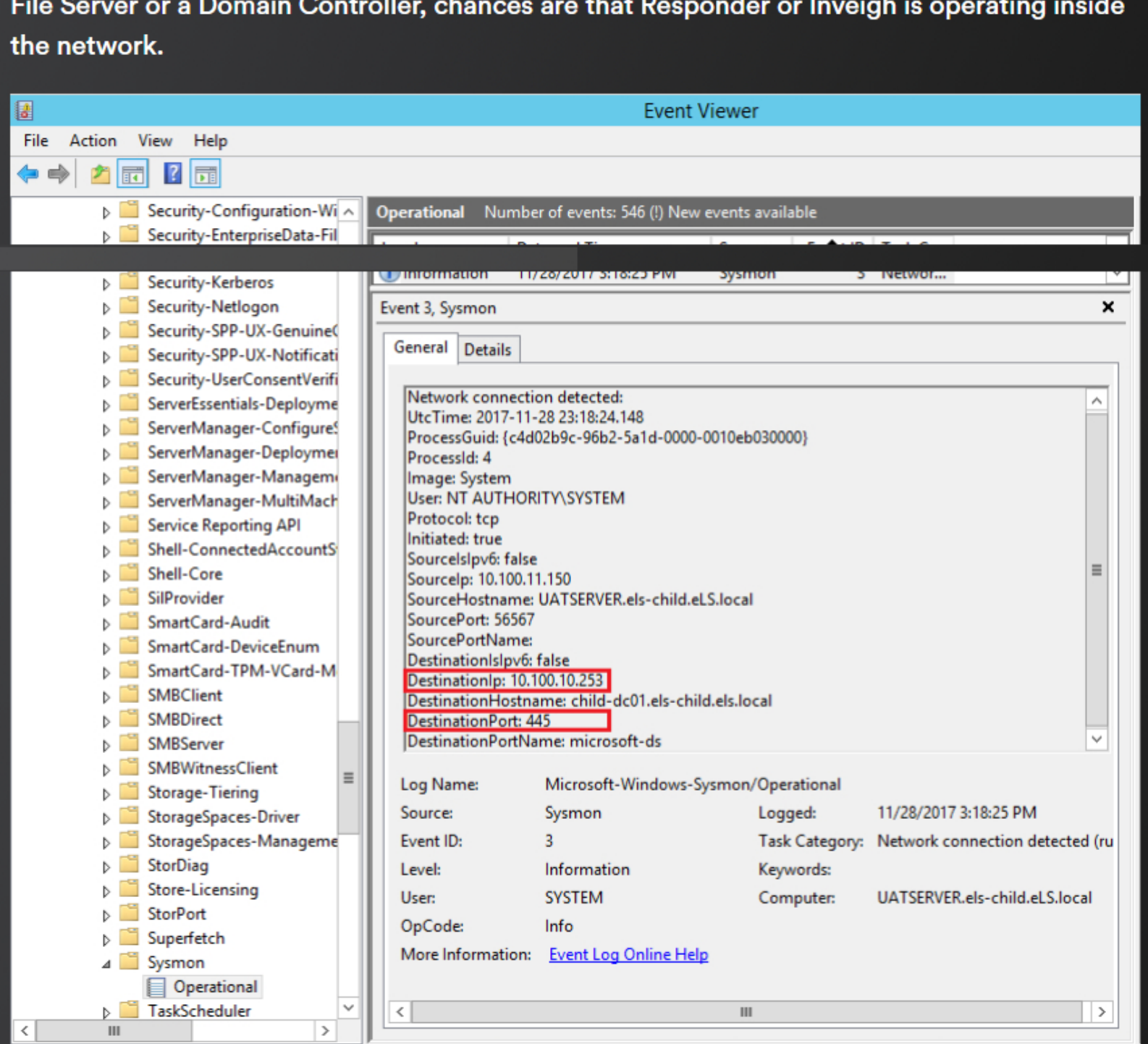
The detection can be performed by looking for any responses regarding the non-existing network resource and also by monitoring the usage of honey credentials.

- Detecting ill-intended responses can be performed by checking if a UDP-based response was returned, for the non-existing network resource you deliberately requested. PowerShell and especially the CredDefense suite can assist you in that.
- Detecting the usage of honey credentials can be performed by analyzing a machine's explicit credentials can help you in detecting if any honey credentials were used. PowerShell's Get-EventLog (https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-powershell-1.0/ee176846(v=technet.10)?redirectedfrom=MSDN) function will certainly prove handy.

Task 2: Detect suspicious interactions with untrusted IP's

Sysmon is able to collect all interactions of a network asset with other assets in the network. If you query those Sysmon logs for any SMB (or NetBIOS)-related communications with an untrusted IP, you will be able to identify if Responder or Inveigh is operating inside the network.

Specifically, Sysmon's Event ID 3 contains all the information you need to detect any SMB (or NetBIOS)-related communications with an untrusted IP. If the Destination IP is not a trusted File Server or a Domain Controller, chances are that Responder or Inveigh is operating inside the network.


Event Viewer
File Action View Help
Security-Configuration-Wi
Security-EnterpriseData-Fil
Security-Kerberos
Security-Netlogon
Security-SPP-UX-Genuine
Security-SPP-UX-Notificati
Security-UserConsentVerifi
ServerEssentials-Deployme
ServerManager-Configure
ServerManager-Deployme
ServerManager-Managem
ServerManager-MultiMach
Service Reporting API
Shell-ConnectedAccountS
Shell-Core
SilProvider
SmartCard-Audit
SmartCard-DeviceEnum
SmartCard-TPM-VCard-M
SMBClient
SMBDirect
SMBServer
SMBWitnessClient
Storage-Tiering
StorageSpaces-Driver
StorageSpaces-Manageme
StorDiag
Store-Licensing
StorPort
Superfetch
Sysmon
Operational
TaskScheduler
Operational Number of events: 546 (!) New events available
Event 3, Sysmon
General Details

```
Network connection detected:
UtcTime: 2017-11-28 23:18:24.148
ProcessGuid: {c4d02b9c-96b2-5a1d-0000-0010eb030000}
ProcessId: 4
Image: System
User: NT AUTHORITY\SYSTEM
Protocol: tcp
Initiated: true
SourceIsIpv6: false
SourceIp: 10.100.11.150
SourceHostname: UATSERVER.els-child.eLS.local
SourcePort: 56567
SourcePortName:
DestinationIsIpv6: false
DestinationIp: 10.100.10.253
DestinationHostname: child-dc01.els-child.els.local
DestinationPort: 445
DestinationPortName: microsoft-ds

Log Name:        Microsoft-Windows-Sysmon/Operational
Source:          Sysmon            Logged:         11/28/2017 3:18:25 PM
Event ID:        3                 Task Category:  Network connection detected (ru
Level:           Information       Keywords:
User:            SYSTEM            Computer:       UATSERVER.els-child.eLS.local
OpCode:          Info
More Information: Event Log Online Help
```

Task 3: Use PowerShell's capabilities to detect Inveigh

Latest PowerShell versions introduced some great blue team-oriented capabilities. One of those capabilities is PowerShell Script Block logging. Script block logging records blocks of code during execution. As a result a script's entire functionality can be recorded and then analyzed. Due to the way script block logging operates, de-obfuscated code can also be recorded, as it is being executed. All logs are recorded into the 'Applications and Services Logs' - Microsoft - Windows -PowerShell - Operational log, under the Event ID 4104.

Inveigh, the PowerShell counterpart of Responder, is considered an extremely effective attacking tool, since it can be executed externally. By enabling PowerShell's script block logging you could easily spot Inveigh running on an endpoint's memory.

Solutions

Below, you can find solutions for each task. Remember, though, that you can follow your own strategy, which may be different from the one explained in the following lab.

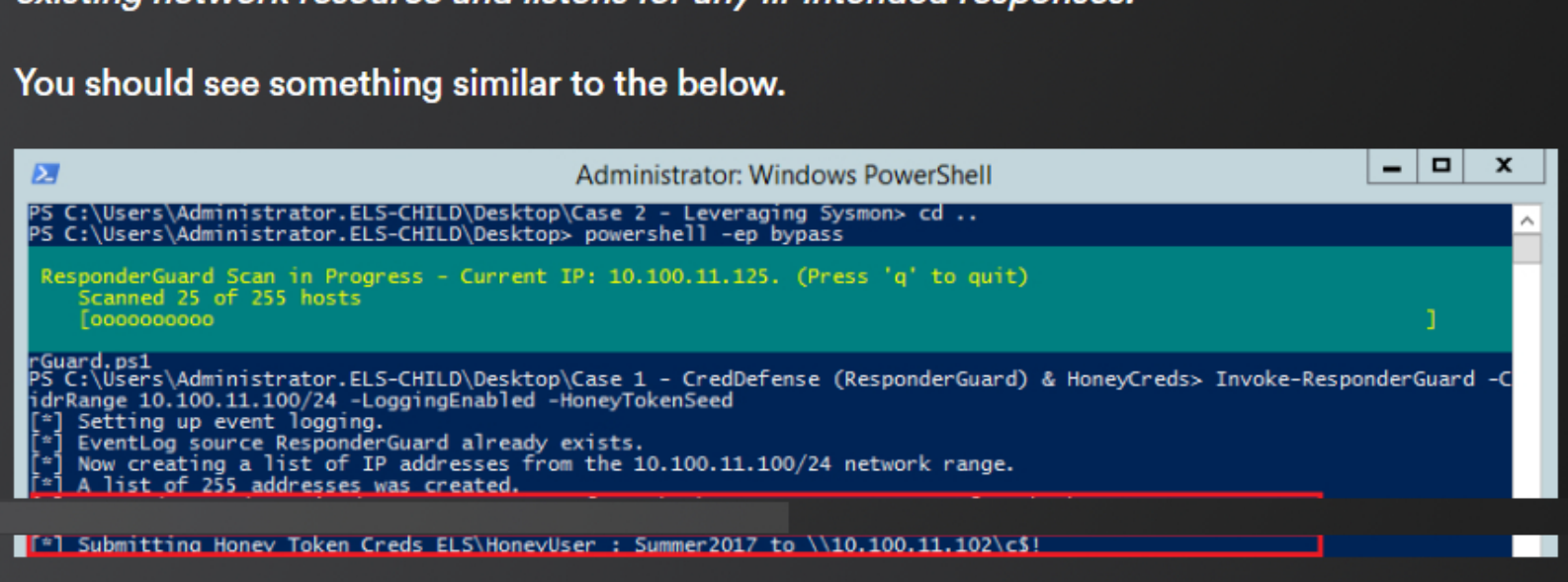
Task 1. Detect malicious responses and rogue authentication servers inside the network

Once you are logged in to the lab, open a PowerShell terminal as Administrator, navigate to the **Case 1 - CredDefense (ResponderGuard) & HoneyCreds** folder, which is located in the Desktop (c:\users\ineadmin\desktop) and execute the following. [ResponderGuard is part the CredDefense suite]

```
powershell -ep bypass
Import-Module .\ResponderGuard.ps1
Invoke-ResponderGuard -CidrRange 10.100.11.0/24 -LoggingEnabled -HoneyTokenSeed
```

If you inspect ResponderGuard's code, you will see that it deliberately requests for a non-existing network resource and listens for any ill-intended responses.

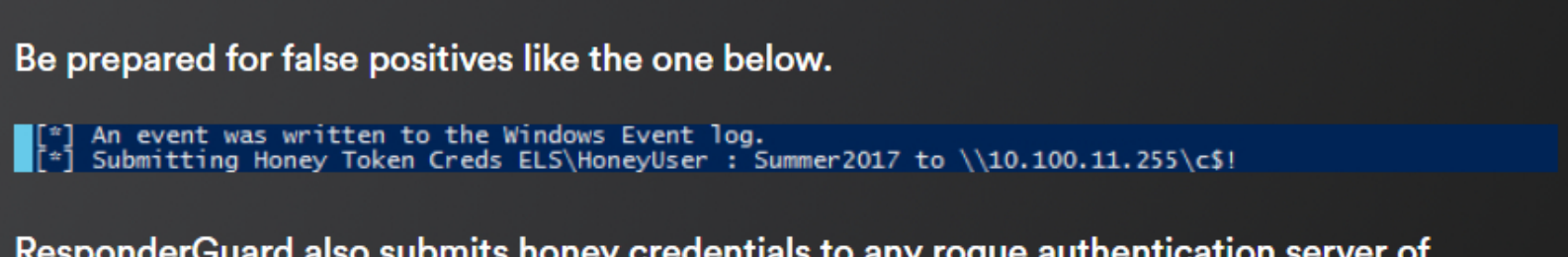
You should see something similar to the below.


Administrator: Windows PowerShell

```
PS C:\Users\Administrator.ELS-CHILD\Desktop\Case 2 - Leveraging Sysmon> cd ..
PS C:\Users\Administrator.ELS-CHILD\Desktop> powershell -ep bypass
 ResponderGuard Scan in Progress - Current IP: 10.100.11.125. (Press 'q' to quit)
    Scanned 25 of 255 hosts
    [oooooooooo                                                          ]
rGuard.ps1
PS C:\Users\Administrator.ELS-CHILD\Desktop\Case 1 - CredDefense (ResponderGuard) & HoneyCreds> Invoke-ResponderGuard -C
idrRange 10.100.11.100/24 -LoggingEnabled -HoneyTokenSeed
[*] Setting up event logging.
[*] EventLog source ResponderGuard already exists.
[*] Now creating a list of IP addresses from the 10.100.11.100/24 network range.
[*] A list of 255 addresses was created.
[*] Submitting Honey Token Creds ELS\HoneyUser : Summer2017 to \\10.100.11.102\c$!
```

The above means that Responder or Inveigh is present in the network, since we got a response for a non-existing network resource.

Be prepared for false positives like the one below.

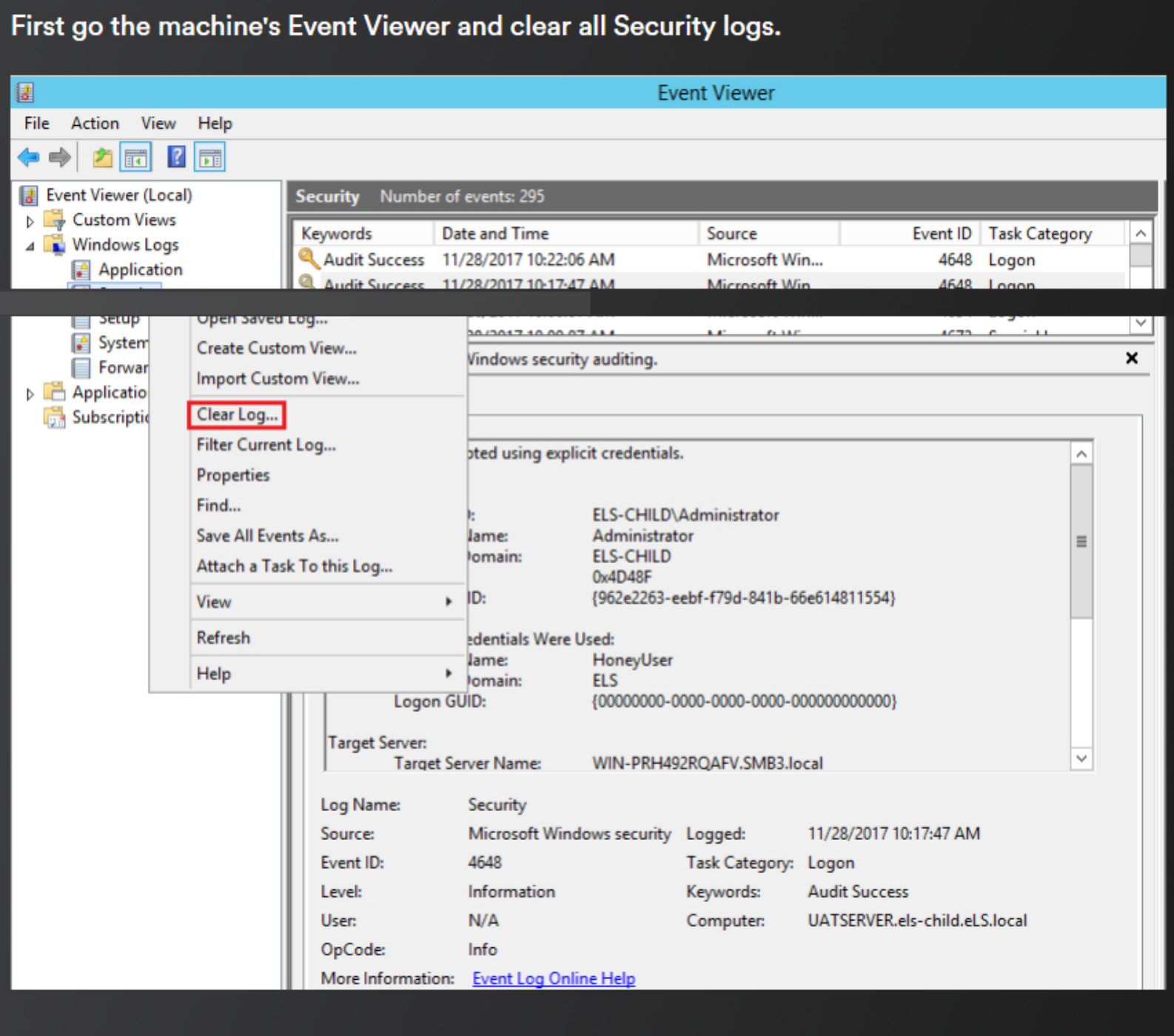


```
[*] An event was written to the Windows Event log.
[*] Submitting Honey Token Creds ELS\HoneyUser : Summer2017 to \\10.100.11.255\c$!
```

ResponderGuard also submits honey credentials to any rogue authentication server of Responder or Inveigh that is detected. So, we can also detect Responder or Inveigh operating inside the network by monitoring the usage of those credentials. As already mentioned the security Event ID that is of interest when looking for such threats, is Event ID **4648 - A logon was attempted using explicit credentials**.

We can monitor and query the logs associated with the Event ID 4648 as follows.

First go the machine's Event Viewer and clear all Security logs.


Event Viewer
File Action View Help
Event Viewer (Local)
Custom Views
Windows Logs
Application
Setup
System
Forwar
Applicatio
Subscripti
Open Saved Log...
Create Custom View...
Import Custom View...
Clear Log...
Filter Current Log...
Properties
Find...
Save All Events As...
Attach a Task To this Log...
View
Refresh
Help
Security Number of events: 295
Keywords Date and Time Source Event ID Task Category

```
Audit Success  11/28/2017 10:22:06 AM  Microsoft Win...  4648  Logon
Audit Success  11/28/2017 10:17:47 AM  Microsoft Win...  4648  Logon

Windows security auditing.
pted using explicit credentials.
  :               ELS-CHILD\Administrator
  lame:           Administrator
  omain:          ELS-CHILD
                  0x4D48F
  ID:             {962e2263-eebf-f79d-841b-66e614811554}
edentials Were Used:
  lame:           HoneyUser
  omain:          ELS
  Logon GUID:     {00000000-0000-0000-0000-000000000000}
Target Server:
  Target Server Name:  WIN-PRH492RQAFV.SMB3.local

Log Name:  Security
Source:    Microsoft Windows security   Logged:         11/28/2017 10:17:47 AM
Event ID:  4648                         Task Category:  Logon
Level:     Information                  Keywords:       Audit Success
User:      N/A                          Computer:       UATSERVER.els-child.eLS.local
OpCode:    Info
More Information: Event Log Online Help
```

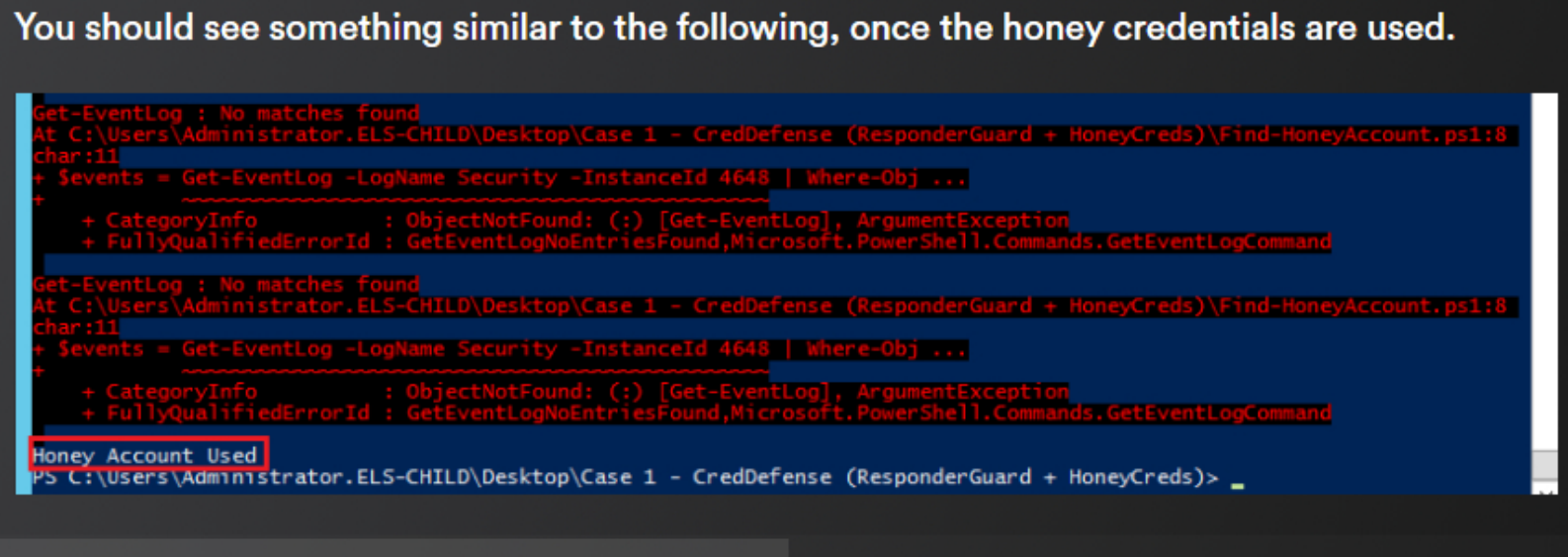
Then open a PowerShell terminal as Administrator, navigate to the **Case 1 - CredDefense (ResponderGuard) & HoneyCreds** folder, which is located in the Desktop and execute the following. (Or use your existing session if it is still open)

```
powershell -ep bypass
Import-Module .\ResponderGuard.ps1
Invoke-ResponderGuard -CidrRange 10.100.11.0/24 -LoggingEnabled -HoneyTokenSeed
```

and concurrently execute in another PowerShell terminal (run again as Administrator) the below

```
powershell -ep bypass
Import-Module .\Find-HoneyAccount.ps1
Find-HoneyAccount HoneyUser
```

You should see something similar to the following, once the honey credentials are used.



```
Get-EventLog : No matches found
At C:\Users\Administrator.ELS-CHILD\Desktop\Case 1 - CredDefense (ResponderGuard + HoneyCreds)\Find-HoneyAccount.ps1:8
char:11
+ $events = Get-EventLog -LogName Security -InstanceId 4648 | Where-Obj ...
+           ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ObjectNotFound: (:) [Get-EventLog], ArgumentException
    + FullyQualifiedErrorId : GetEventLogNoEntriesFound,Microsoft.PowerShell.Commands.GetEventLogCommand

Get-EventLog : No matches found
At C:\Users\Administrator.ELS-CHILD\Desktop\Case 1 - CredDefense (ResponderGuard + HoneyCreds)\Find-HoneyAccount.ps1:8
char:11
+ $events = Get-EventLog -LogName Security -InstanceId 4648 | Where-Obj ...
+           ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ObjectNotFound: (:) [Get-EventLog], ArgumentException
    + FullyQualifiedErrorId : GetEventLogNoEntriesFound,Microsoft.PowerShell.Commands.GetEventLogCommand

Honey Account Used
PS C:\Users\Administrator.ELS-CHILD\Desktop\Case 1 - CredDefense (ResponderGuard + HoneyCreds)> _
```

Find-HoneyAccount.ps1 content:

```
 $Print = "Honey Account Used";
function Find-HoneysAccount {
  Param(
    [String]$AccountName
  )
  while($True) {
    $events = Get-EventLog -LogName Security -InstanceId 4648 | Where-Object { $_.Mes
    }
    $events | ForEach-Object {
      $_.Message -match "Account Name:(?<content>.*)$($AccountName)" | Out-Null
      $Print;exit
    }
  }
}
```

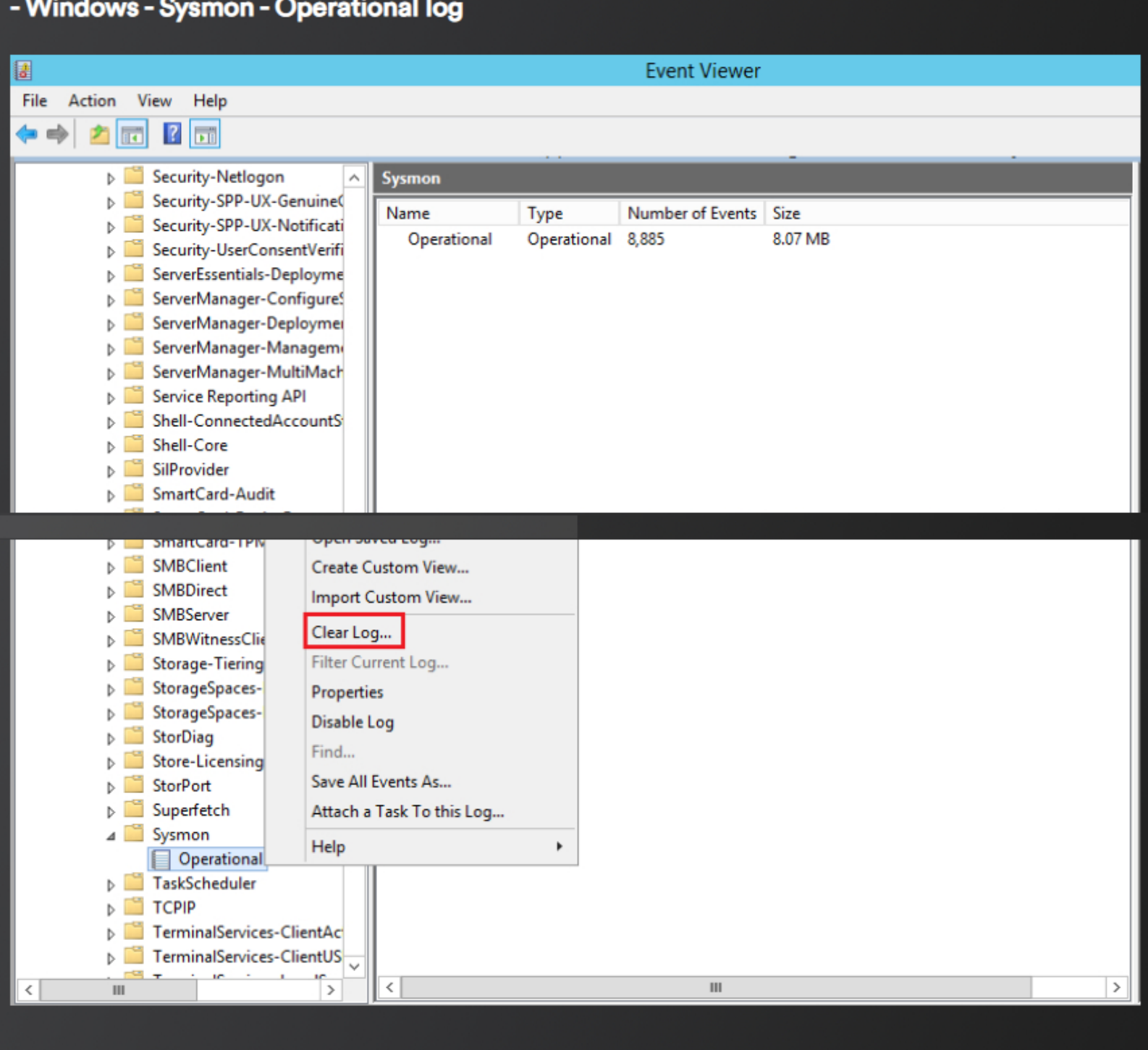
This is how you can query a machine's Security logs using PowerShell

---

Let's now leverage Sysmon to try and identify any SMB (or NetBIOS)-related communications with an untrusted IP. If the destination IP is an IP other the one of a trusted file server or a domain controller, then Responder or Inveigh may be operating inside the network.

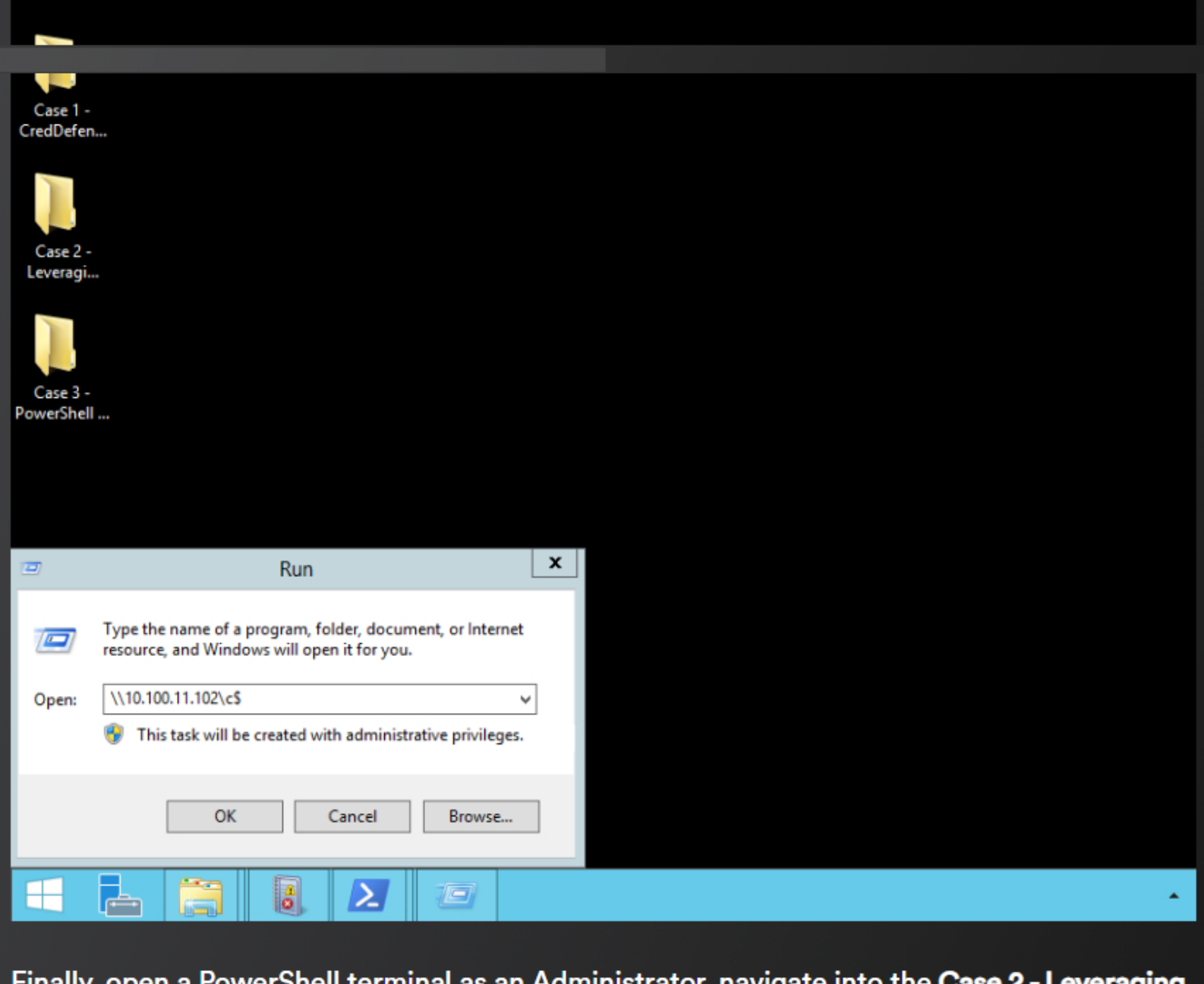
As mentioned, the Sysmon Event ID that is of interest when looking for any SMB (or NetBIOS)-related communications with an untrusted IP, is Sysmon Event ID 3.

First go the machine's Event Viewer and clear the **'Applications and Services Logs' - Microsoft - Windows - Sysmon - Operational log**


Event Viewer
File Action View Help
Security-Netlogon
Security-SPP-UX-Genuine
Security-SPP-UX-Notificati
Security-UserConsentVerifi
ServerEssentials-Deployme
ServerManager-Configure
ServerManager-Deployme
ServerManager-Managem
ServerManager-MultiMach
Service Reporting API
Shell-ConnectedAccountS
Shell-Core
SilProvider
SmartCard-Audit
SMBClient
SMBDirect
SMBServer
SMBWitnessClie
Storage-Tiering
StorageSpaces-
StorageSpaces-
StorDiag
Store-Licensing
StorPort
Superfetch
Sysmon
Operational
TaskScheduler
TCPIP
TerminalServices-ClientAc
TerminalServices-ClientUS
Open Saved Log...
Create Custom View...
Import Custom View...
Clear Log...
Filter Current Log...
Properties
Disable Log
Find...
Save All Events As...
Attach a Task To this Log...
Help
Sysmon
Name Type Number of Events Size
Operational Operational 8,885 8.07 MB

Then, simulate an SMB connection with Responder's rogue authentication server. (This is actually similar to what will happen in the background if Responder is operating inside the network)

Right click on Windows (bottom-right corner) - Run - **\\10.100.11.102\c$**

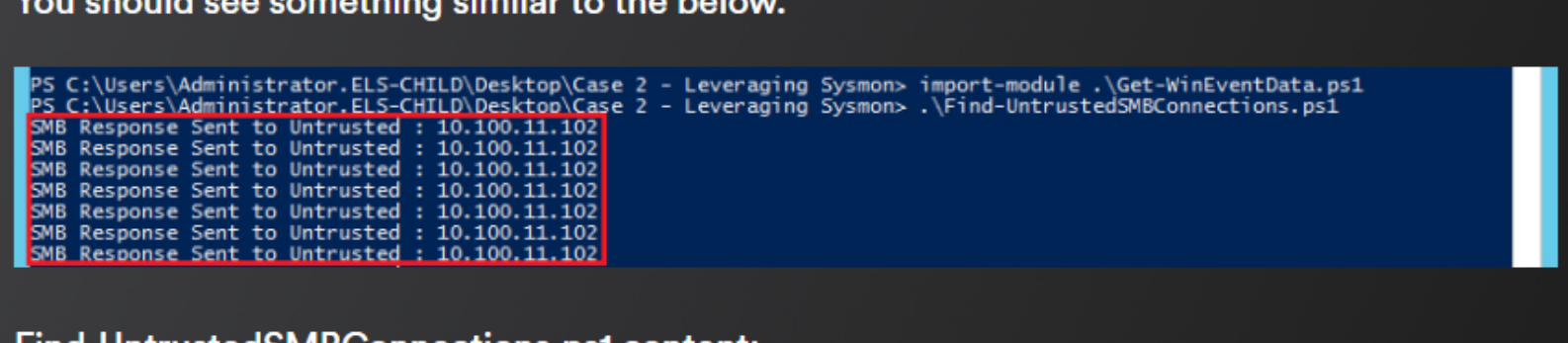

Recycle Bin
Case 1 - CredDefen...
Case 2 - Leveragi...
Case 3 - PowerShell ...
Run
Type the name of a program, folder, document, or Internet resource, and Windows will open it for you.
This task will be created with administrative privileges.
OK
Cancel
Browse...

Open: \\10.100.11.102\c$

Finally, open a PowerShell terminal as an Administrator, navigate into the **Case 2 - Leveraging Sysmon** folder, which is located in the Desktop and execute the following.

```
powershell -ep bypass
Import-Module .\Get-WinEventData.ps1
.\Find-UntrustedSMBConnections.ps1
```

You should see something similar to the below.



```
PS C:\Users\Administrator.ELS-CHILD\Desktop\Case 2 - Leveraging Sysmon> import-module .\Get-WinEventData.ps1
PS C:\Users\Administrator.ELS-CHILD\Desktop\Case 2 - Leveraging Sysmon> .\Find-UntrustedSMBConnections.ps1
SMB Response Sent to Untrusted : 10.100.11.102
SMB Response Sent to Untrusted : 10.100.11.102
SMB Response Sent to Untrusted : 10.100.11.102
SMB Response Sent to Untrusted : 10.100.11.102
SMB Response Sent to Untrusted : 10.100.11.102
SMB Response Sent to Untrusted : 10.100.11.102
SMB Response Sent to Untrusted : 10.100.11.102
```

Find-UntrustedSMBConnections.ps1 content:

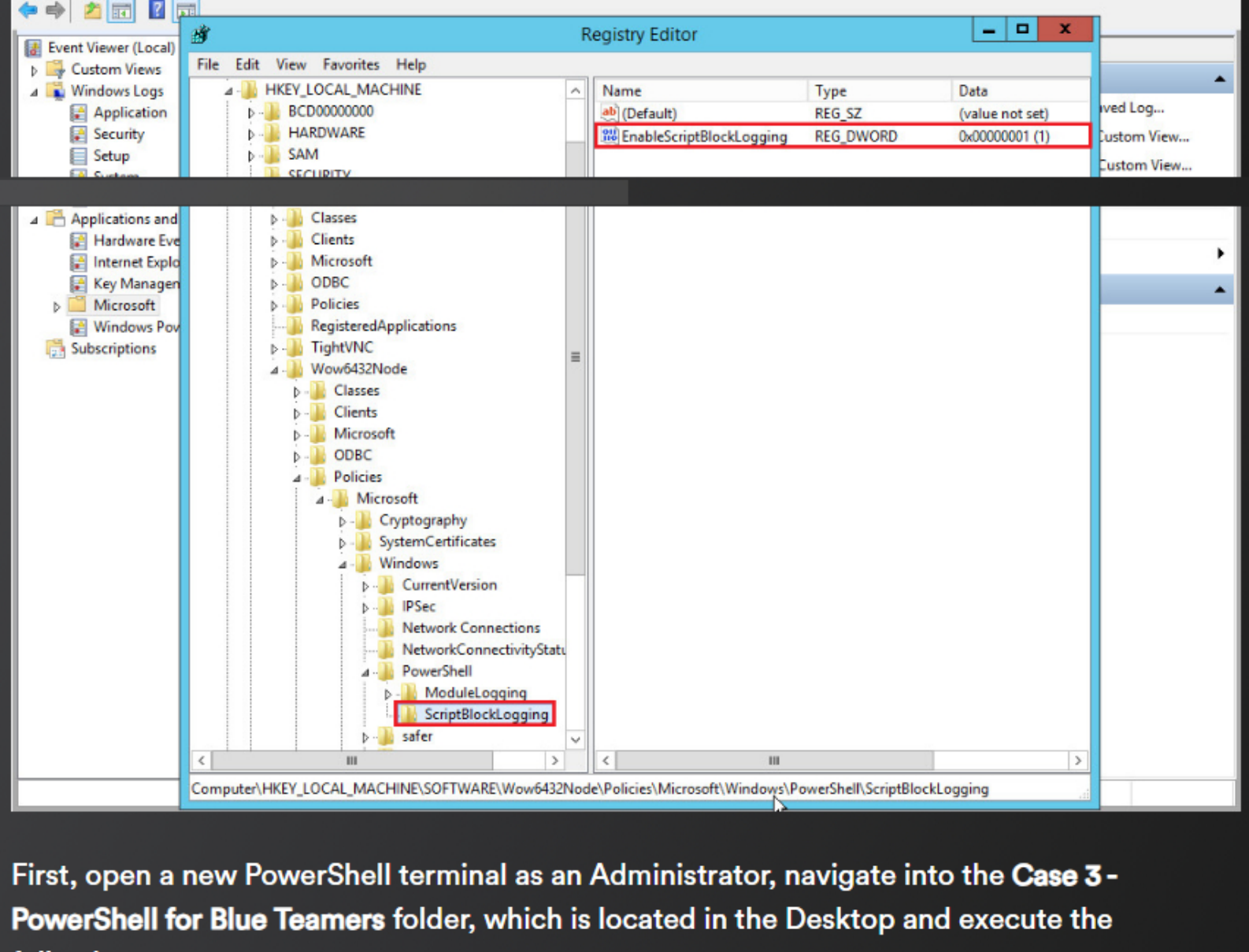
```
 #credits to haveyousecured.blogspot.gr
Import-Module Get-WinEventData.ps1
Set-Location \\nonexisting\sharenotthere -ErrorAction SilentlyContinue
$EventsID3  =  Get-WinEvent -FilterHashtable @{logname="Microsoft-Windows-Sysmon/Opera
foreach($Event3 in $EventsID3){
    if(($Event3.EventDataDestinationPort -eq 445) -and ($Event3.EventDataDestinationI

}
}
```

This is how you can query a machine's Sysmon logs using PowerShell

You could also use the script above for port 139 (NetBIOS).

Task 3. Use PowerShell's capabilities to detect Inveigh

Let's now leverage PowerShell's Script Block Logging capability. You can enable script block logging on a Windows Server 2012 if Windows Management Framework (WMF) 5.0 and .Net 4.5 are already installed and the following registry key and DWORD are configured, as follows.

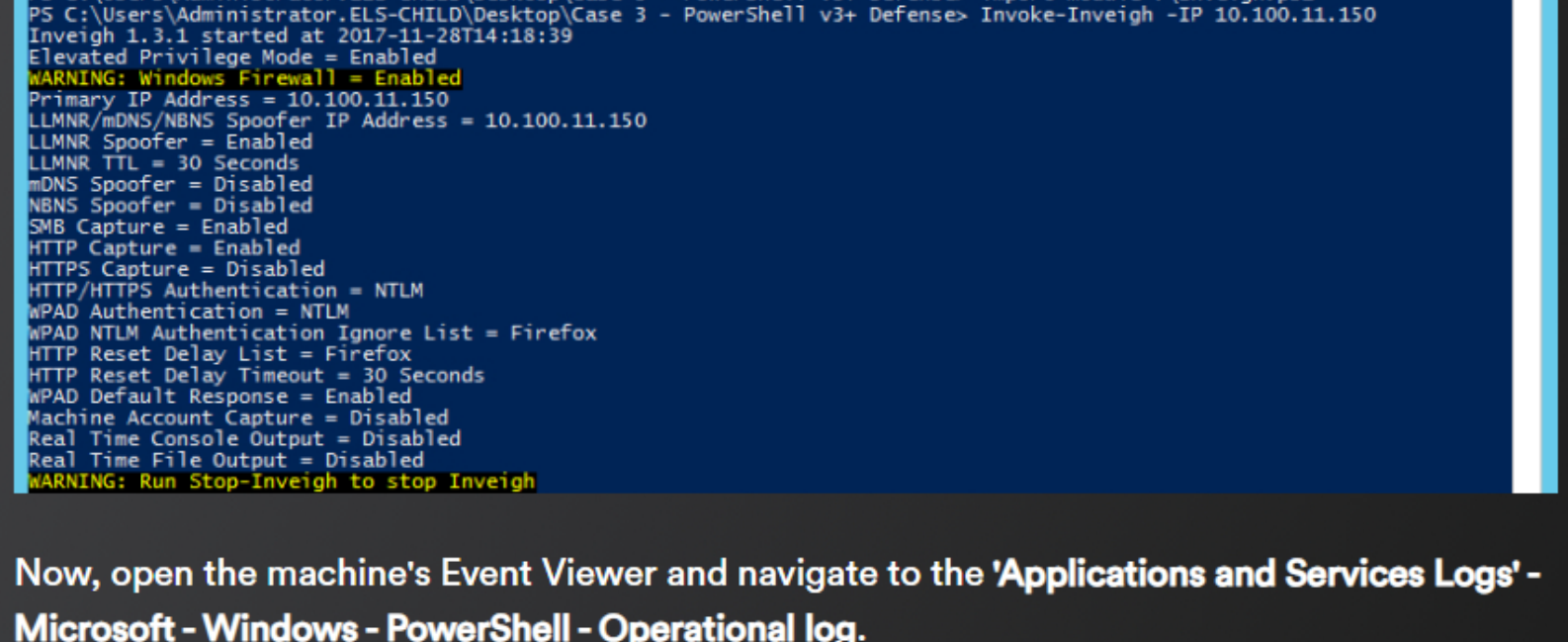

Event Viewer
Registry Editor
File Edit View Favorites Help
HKEY_LOCAL_MACHINE
BCD00000000
HARDWARE
SAM
Classes
Clients
Microsoft
ODBC
Policies
RegisteredApplications
TightVNC
Wow6432Node
Classes
Clients
Microsoft
ODBC
Policies
Microsoft
Cryptography
SystemCertificates
Windows
CurrentVersion
IPSec
Network Connections
NetworkConnectivityStatu
PowerShell
ModuleLogging
ScriptBlockLogging
safer
Name Type Data

```
(Default)                 REG_SZ      (value not set)
EnableScriptBlockLogging  REG_DWORD   0x00000001 (1)

Computer\HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging
```

First, open a new PowerShell terminal as an Administrator, navigate into the **Case 3 - PowerShell for Blue Teamers** folder, which is located in the Desktop and execute the following.

```
powershell -ep bypass
Import-Module .\Inveigh.ps1
```

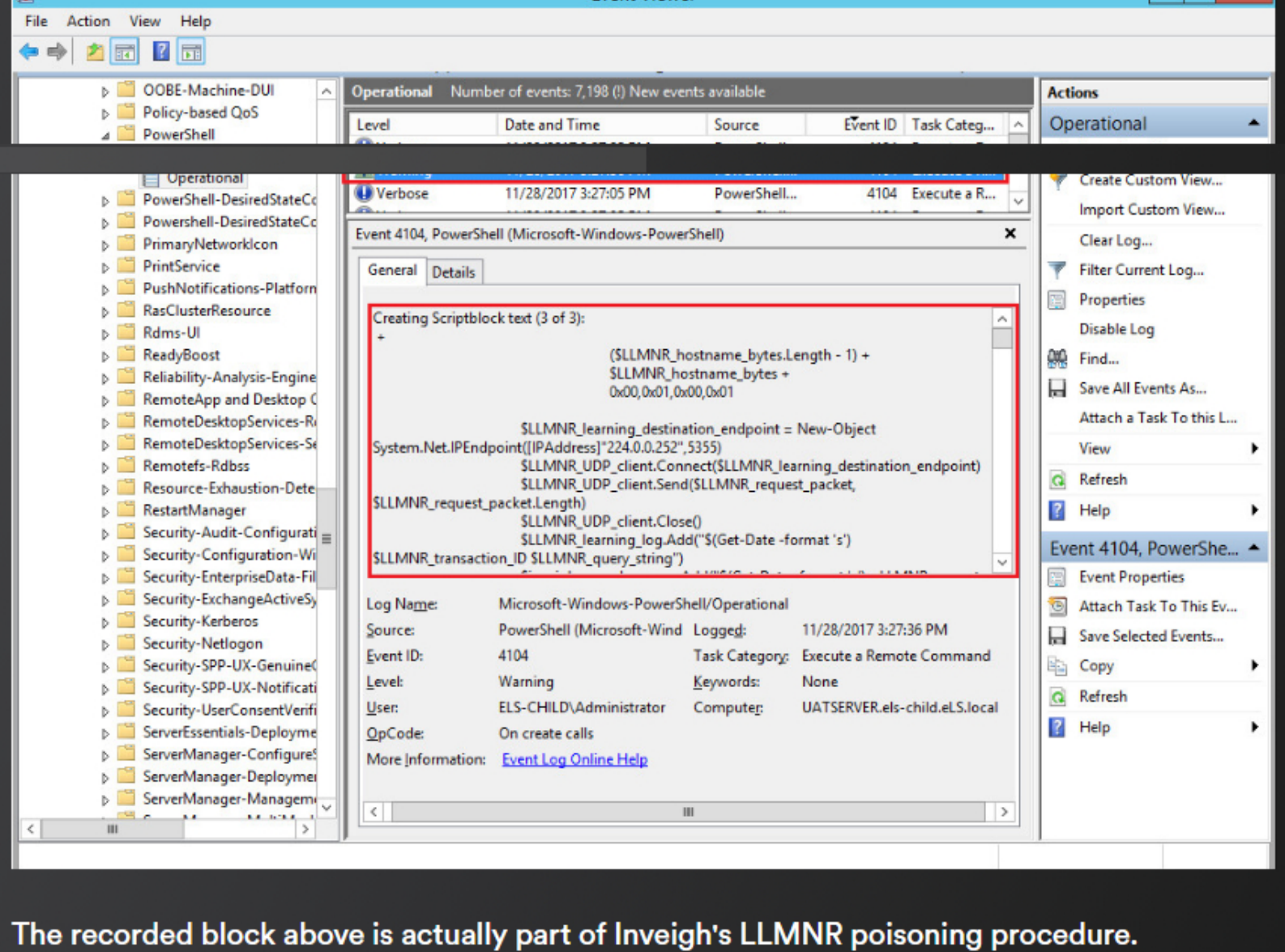
You should see something similar to the below.



```
PS C:\Users\Administrator.ELS-CHILD> cd '.\Desktop\Case 3 - PowerShell v3+ Defense'
PS C:\Users\Administrator.ELS-CHILD\Desktop\Case 3 - PowerShell v3+ Defense> import-module .\Inveigh.ps1
PS C:\Users\Administrator.ELS-CHILD\Desktop\Case 3 - PowerShell v3+ Defense> Invoke-Inveigh -IP 10.100.11.150
Inveigh 1.3.1 started at 2017-11-28T14:18:39
Elevated Privilege Mode = Enabled
WARNING: Windows Firewall = Enabled
Primary IP Address = 10.100.11.150
LLMNR/mDNS/NBNS Spoofer IP Address = 10.100.11.150
LLMNR Spoofer = Enabled
LLMNR TTL = 30 Seconds
mDNS Spoofer = Disabled
NBNS Spoofer = Disabled
SMB Capture = Enabled
HTTP Capture = Enabled
HTTPS Capture = Disabled
HTTP/HTTPS Authentication = NTLM
WPAD Authentication = NTLM
WPAD NTLM Authentication Ignore List = Firefox
HTTP Reset Delay List = Firefox
HTTP Reset Delay Timeout = 30 Seconds
WPAD Default Response = Enabled
Machine Account Capture = Disabled
Real Time Console Output = Disabled
Real Time File Output = Disabled
WARNING: Run Stop-Inveigh to stop Inveigh
```

Now, open the machine's Event Viewer and navigate to the **'Applications and Services Logs' - Microsoft - Windows - PowerShell - Operational log.**

You should see something similar to the below.


Event Viewer
File Action View Help
OOBE-Machine-DUI
Policy-based QoS
PowerShell
Operational
PowerShell-DesiredStateCo
PowerShell-DesiredStateCo
PrimaryNetworkIcon
PrintService
PushNotifications-Platform
RasClusterResource
Rdms-UI
ReadyBoost
Reliability-Analysis-Engine
RemoteApp and Desktop C
RemoteDesktopServices-R
RemoteDesktopServices-Se
Remotefs-Rdbss
Resource-Exhaustion-Dete
RestartManager
Security-Audit-Configurati
Security-Configuration-Wi
Security-EnterpriseData-Fil
Security-ExchangeActiveSy
Security-Kerberos
Security-Netlogon
Security-SPP-UX-Genuine
Security-SPP-UX-Notificati
Security-UserConsentVerifi
ServerEssentials-Deployme
ServerManager-Configure
ServerManager-Deployme
ServerManager-Managem
Operational Number of events: 7,198 (!) New events available
Level Date and Time Source Event ID Task Categ...
Event 4104, PowerShell (Microsoft-Windows-PowerShell)
General Details
Actions
Operational
Create Custom View...
Import Custom View...
Clear Log...
Filter Current Log...
Properties
Disable Log
Find...
Save All Events As...
Attach a Task To this L...
View
Refresh
Help
Event 4104, PowerShe...
Event Properties
Attach Task To This Ev...
Save Selected Events...
Copy
Refresh
Help

```
Verbose  11/28/2017 3:27:05 PM  PowerShell...  4104  Execute a R...

Creating Scriptblock text (3 of 3):
+
                    ($LLMNR_hostname_bytes.Length - 1) +
                    $LLMNR_hostname_bytes +
                    0x00,0x01,0x00,0x01
            $LLMNR_learning_destination_endpoint = New-Object
System.Net.IPEndpoint([IPAddress]"224.0.0.252",5355)
            $LLMNR_UDP_client.Connect($LLMNR_learning_destination_endpoint)
            $LLMNR_UDP_client.Send($LLMNR_request_packet,
$LLMNR_request_packet.Length)
            $LLMNR_UDP_client.Close()
            $LLMNR_learning_log.Add("$(Get-Date -format 's')
$LLMNR_transaction_ID $LLMNR_query_string")

Log Name:  Microsoft-Windows-PowerShell/Operational
Source:    PowerShell (Microsoft-Wind  Logged:         11/28/2017 3:27:36 PM
Event ID:  4104                        Task Category:  Execute a Remote Command
Level:     Warning                     Keywords:       None
User:      ELS-CHILD\Administrator     Computer:       UATSERVER.els-child.eLS.local
OpCode:    On create calls
More Information: Event Log Online Help
```

The recorded block above is actually part of Inveigh's LLMNR poisoning procedure.

To conclude, in this lab four (4) distinct ways were documented that could assist you in detecting Responder or Inveigh on a network, under your supervision.

- CredDefense (listening for UDP-based responses when requesting a non-existing network resource)
- Honey Credentials (Security Event ID **4648**)
- Sysmon (Sysmon Event ID **3**)
- PowerShell's Script Block Logging (PowerShell Operational log - Event ID **4104**)